Materia: Intercomunicación y Seguridad de Redes

Nombre: Miguel Angel De La Cruz Espinosa Fecha: 11 de marzo 2026

Enumeración en Auditoría de Ciberseguridad

Objetivo

Aplicar técnicas de enumeración para identificar usuarios, servicios, recursos compartidos y vectores potenciales de ataque en un sistema Linux objetivo, utilizando herramientas especializadas y análisis manual.

1. Requisitos de trabajo

Atacante: Kali Linux
Objetivo: Máquina Linux vulnerable

Nota: **NO debe explotar**, solo enumerar.

2. Herramientas a utilizar

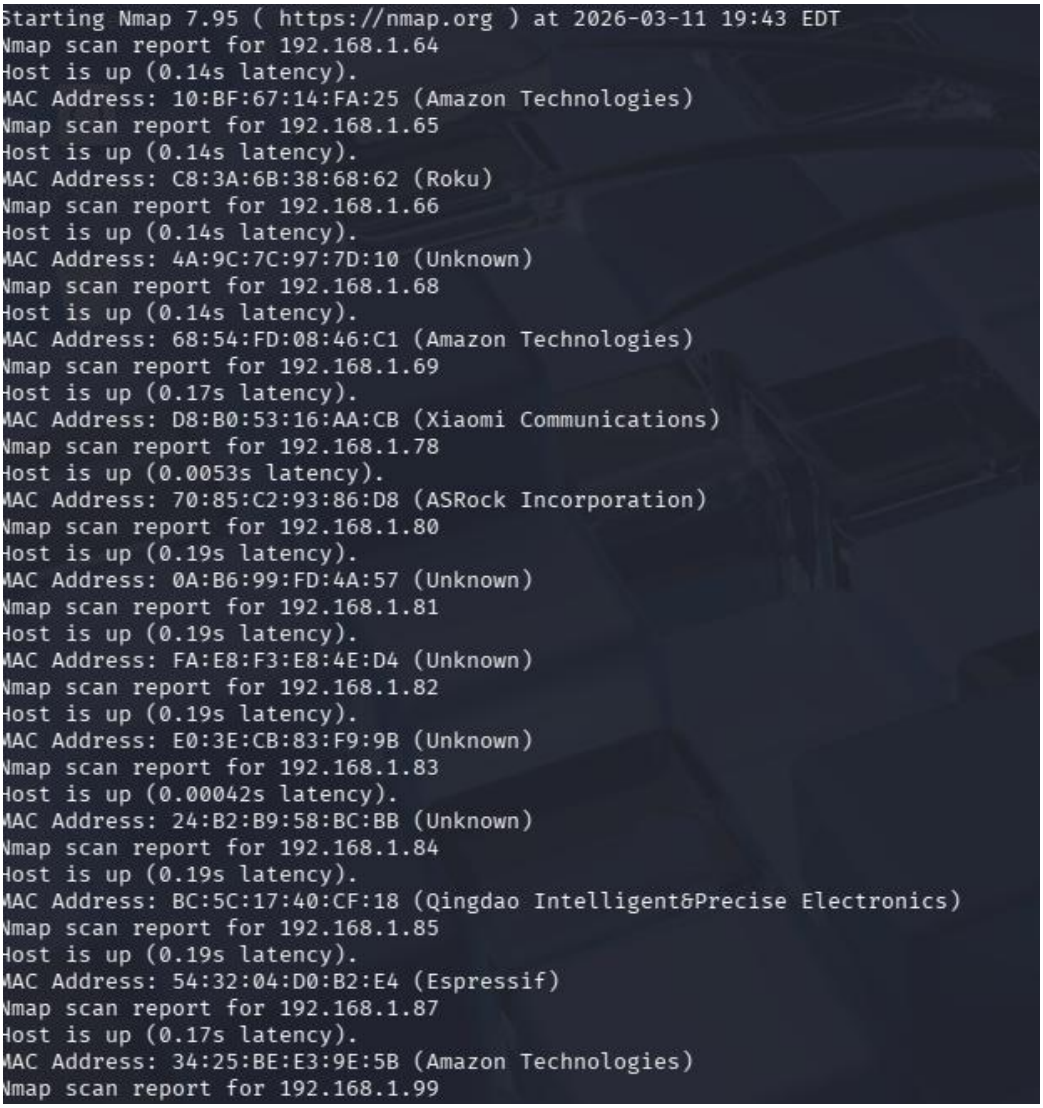
- nmap
- enum4linux
- smbclient
- rpcclient
- nikto
- gobuster
- whatweb
- netcat
- curl

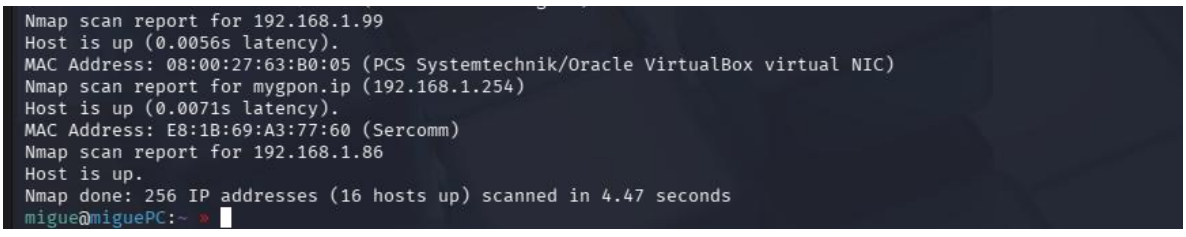
Fase 1. Reconocimiento

2.1 Descubrimiento de host (observe que se no se analiza una dirección IP sino todo un rango de direcciones de red)

```
nmap -sn 192.168.1.0/24
```

Registre sus hallazgos

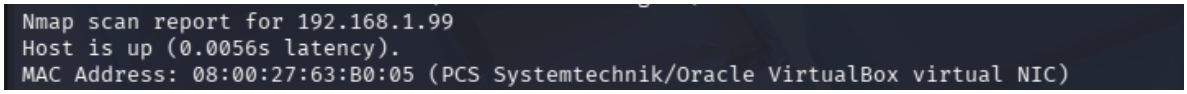




Posteriormente elija la dirección IP de su compañero para iniciar el proceso de enumeración

Registrar:

- IP del objetivo (su compañero)
- hosts activos (en el rango de segmento de red)

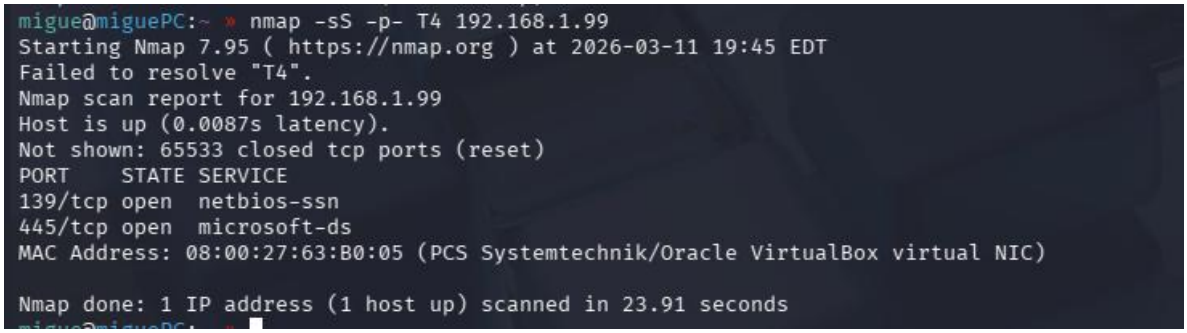


2.2 Escaneo de puertos completo

```
nmap -sS -p- -T4 192.168.1.X
```

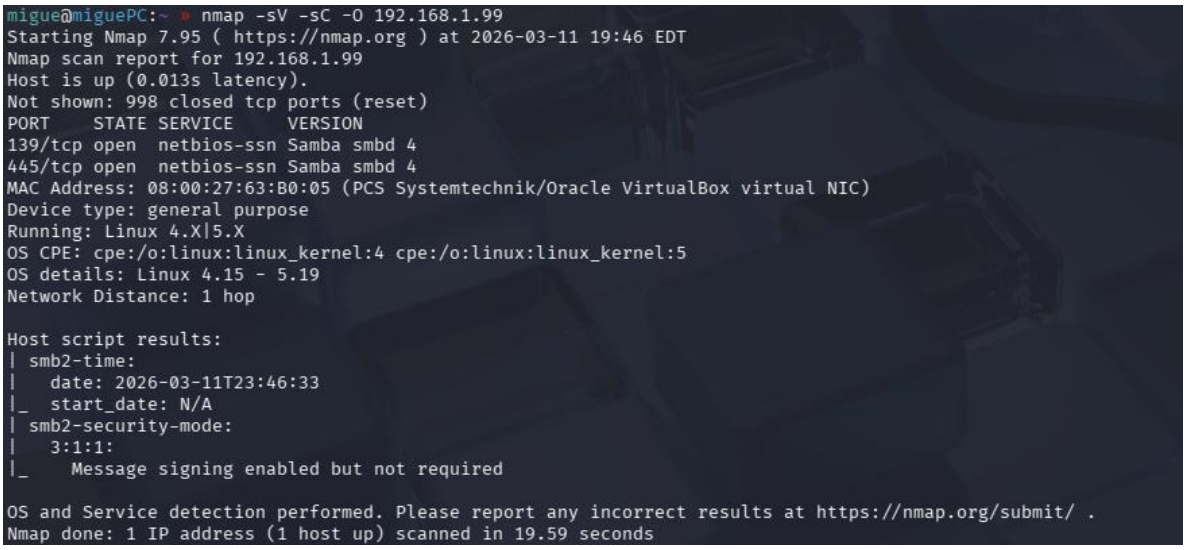
Identificar:

- puertos abiertos
- puertos filtrados
- servicios probables



2.3 Detección de servicios y versiones

```
nmap -sV -sC -O 192.168.1.X
```



Registrar:

- versiones
- sistema operativo estimado
- scripts NSE relevantes

Fase 2. Enumeración por servicio

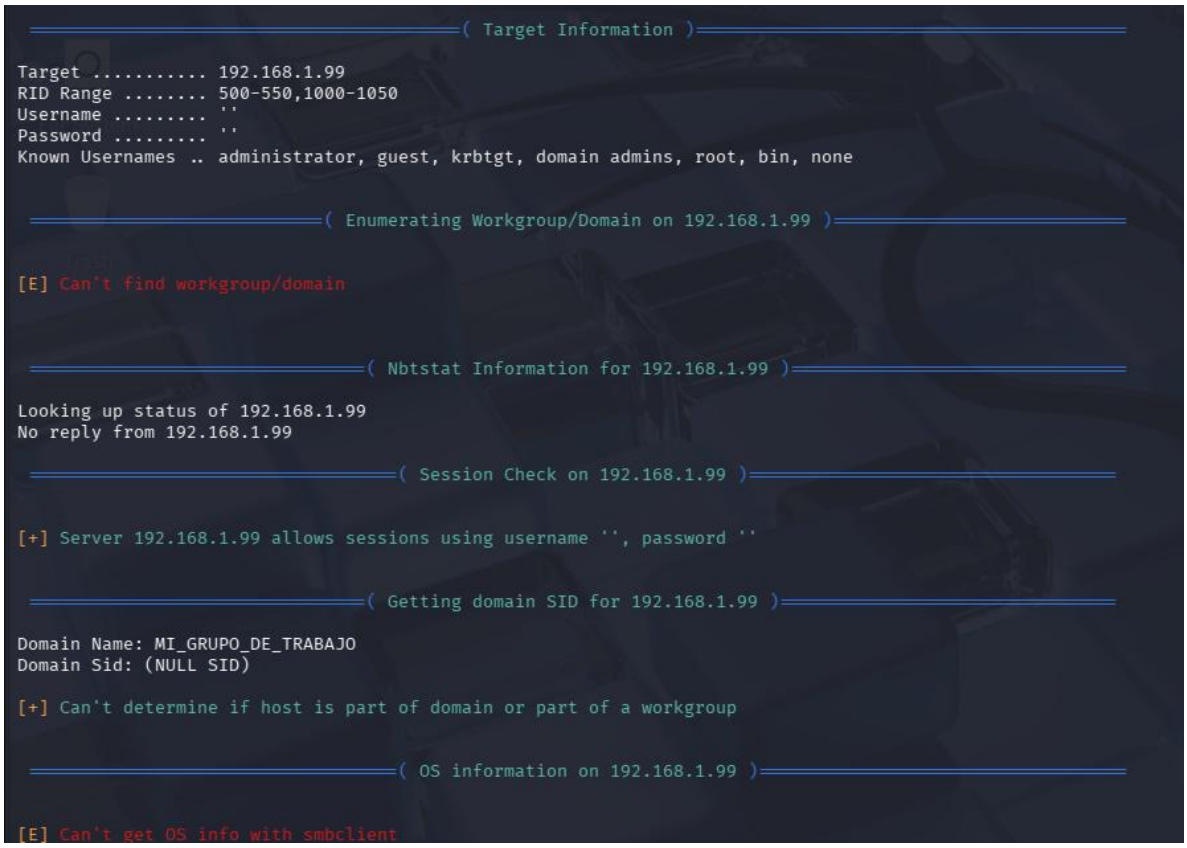
3.1 Enumeración SMB

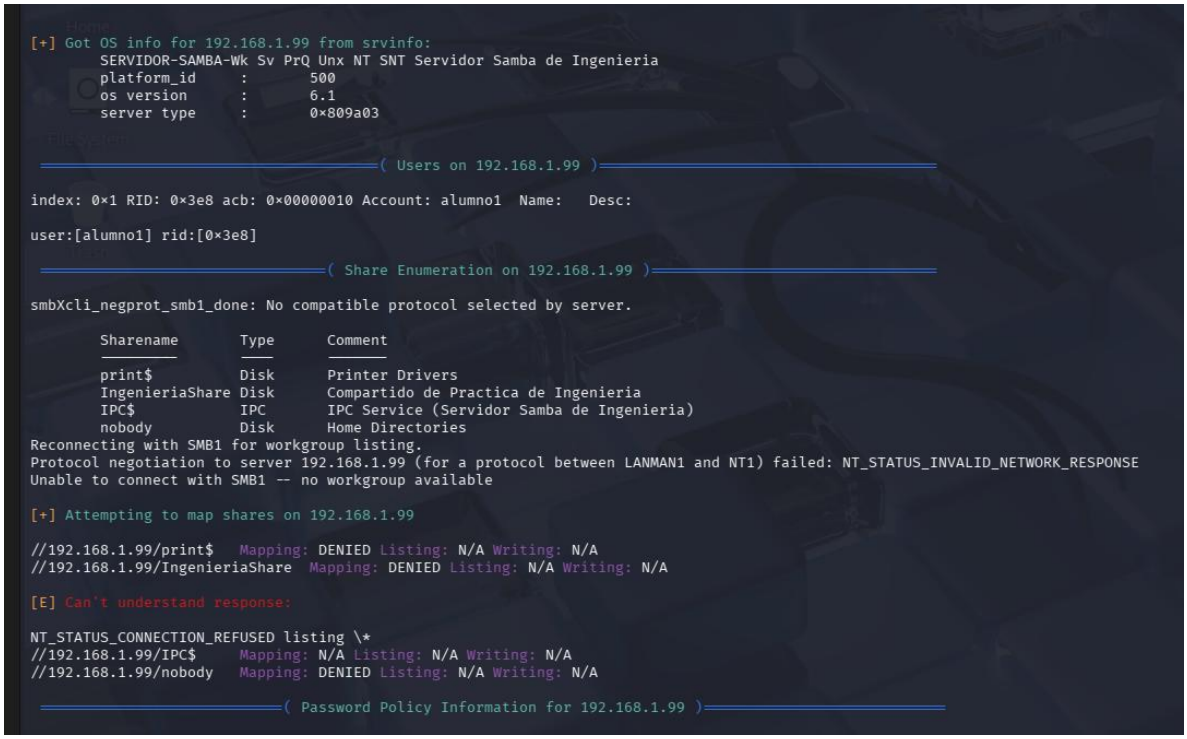
Con enum4linux

```
enum4linux -a 192.168.1.X
```

Buscar:

- usuarios
- shares
- política de contraseñas


(Target Information)
Target 192.168.1.99
RID Range 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
(Enumerating Workgroup/Domain on 192.168.1.99)
[E] Can't find workgroup/domain
(Nbtstat Information for 192.168.1.99)
Looking up status of 192.168.1.99
No reply from 192.168.1.99
(Session Check on 192.168.1.99)
[+] Server 192.168.1.99 allows sessions using username '', password ''
(Getting domain SID for 192.168.1.99)
Domain Name: MI_GRUPO_DE_TRABAJO
Domain Sid: (NULL SID)
[+] Can't determine if host is part of domain or part of a workgroup
(OS information on 192.168.1.99)
[E] Can't get OS info with smbclient


[+] Got OS info for 192.168.1.99 from srvinfo:
SERVIDOR-SAMBA-Wk Sv PrQ Unx NT SNT Servidor Samba de Ingenieria
platform_id : 500
os version : 6.1
server type : 0x809a03
(Users on 192.168.1.99)
index: 0x1 RID: 0x3e8 acb: 0x00000010 Account: alumno1 Name: Desc:
user:[alumno1] rid:[0x3e8]
(Share Enumeration on 192.168.1.99)
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Sharename Type Comment
print$ Disk Printer Drivers
IngenieriaShare Disk Compartido de Practica de Ingenieria
IPC$ IPC IPC Service (Servidor Samba de Ingenieria)
nobody Disk Home Directories
Reconnecting with SMB1 for workgroup listing.
Protocol negotiation to server 192.168.1.99 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
[+] Attempting to map shares on 192.168.1.99
//192.168.1.99/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.1.99/IngenieriaShare Mapping: DENIED Listing: N/A Writing: N/A
[E] Can't understand response:
NT_STATUS_CONNECTION_REFUSED listing *
//192.168.1.99/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.1.99/nobody Mapping: DENIED Listing: N/A Writing: N/A
(Password Policy Information for 192.168.1.99)

```
Session  Actions  Edit  View  Help
Password:


[+] Attaching to 192.168.1.99 using a NULL share

[+] Trying protocol 139/SMB...

[+] Found domain(s):

        [+] SERVIDOR-SAMBA-ING
        [+] Builtin

[+] Password Info for Domain: SERVIDOR-SAMBA-ING

        [+] Minimum password length: 5
        [+] Password history length: None
        [+] Maximum password age: 136 years 37 days 6 hours 21 minutes
        [+] Password Complexity Flags: 000000

                [+] Domain Refuse Password Change: 0
                [+] Domain Password Store Cleartext: 0
                [+] Domain Password Lockout Admins: 0
                [+] Domain Password No Clear Change: 0
                [+] Domain Password No Anon Change: 0
                [+] Domain Password Complex: 0

        [+] Minimum password age: None
        [+] Reset Account Lockout Counter: 30 minutes
        [+] Locked Account Duration: 30 minutes
        [+] Account Lockout Threshold: None
        [+] Forced Log off Time: 136 years 37 days 6 hours 21 minutes


[+] Retieved partial password policy with rpcclient:


Password Complexity: Disabled
Minimum Password Length: 5
```

```
Session  Actions  Edit  View  Help


[+] Getting builtin groups:


[+]  Getting builtin group memberships:


[+]  Getting local groups:


[+]  Getting local group memberships:


[+]  Getting domain groups:


[+]  Getting domain group memberships:


 ==========( Users on 192.168.1.99 via RID cycling (RIDS: 500-550,1000-1050) )==========


[I] Found new SID:
S-1-22-1

[I] Found new SID:
S-1-5-32

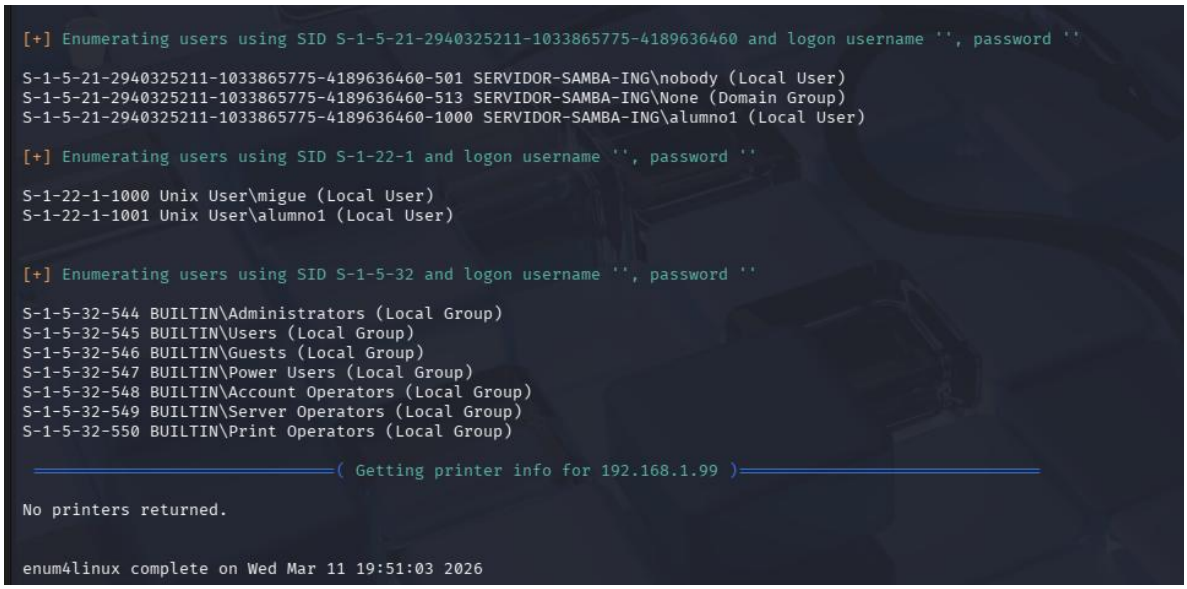
[I] Found new SID:
S-1-5-32

[I] Found new SID:
S-1-5-32

[I] Found new SID:
S-1-5-32

[+] Enumerating users using SID S-1-5-21-2940325211-1033865775-4189636460 and logon username '', password ''

S-1-5-21-2940325211-1033865775-4189636460-501 SERVIDOR-SAMBA-ING\nobody (Local User)
S-1-5-21-2940325211-1033865775-4189636460-513 SERVIDOR-SAMBA-ING\None (Domain Group)
```

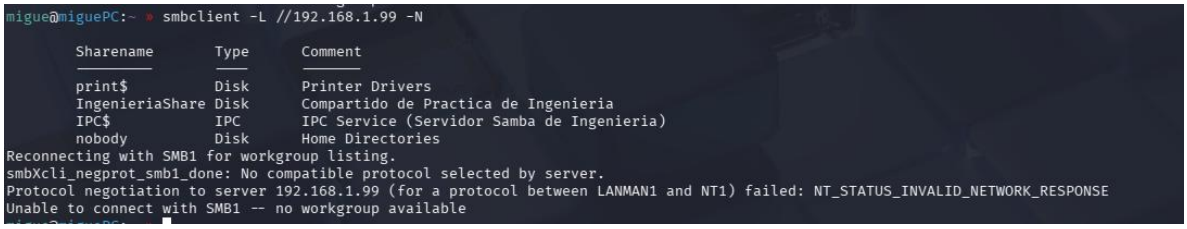


Con smbclient

```
smbclient -L //192.168.1.X -N
```

Registrar:

- recursos compartidos
- acceso anónimo



3.2 Enumeración RPC

```
rpcclient -U "" 192.168.1.X
```

Dentro de la consola:

```
enumdomusers
```

Objetivo: descubrir usuarios del sistema.

```
migue@miguePC:~ » rpcclient -U "" 192.168.1.99
Password for [MI_GRUPO_DE_TRABAJO\]:
rpcclient $> enum
enumalsgroups              enumdomains               enumdrivers
enumdata                   enumdomgroups             enumforms
enumdataex                 enumdomusers              enumjobs
rpcclient $> enumdom
enumdomains    enumdomgroups  enumdomusers
rpcclient $> enumdom
enumdomains    enumdomgroups  enumdomusers
rpcclient $> enumdomusers
user:[alumno1] rid:[0×3e8]
rpcclient $>
```

3.3 Enumeración web

(Si hay puerto 80/443)

Fingerprinting

`whatweb http://192.168.1.X`

```
rpcclient $> what'C
migue@miguePC:~ » whatweb http://192.168.1.99
ERROR Opening: http://192.168.1.99 - Connection refused - connect(2) for "192.168.1.99" port 80
migue@miguePC:~ »
```

Escaneo de vulnerabilidades web

`nikto -h http://192.168.1.X`

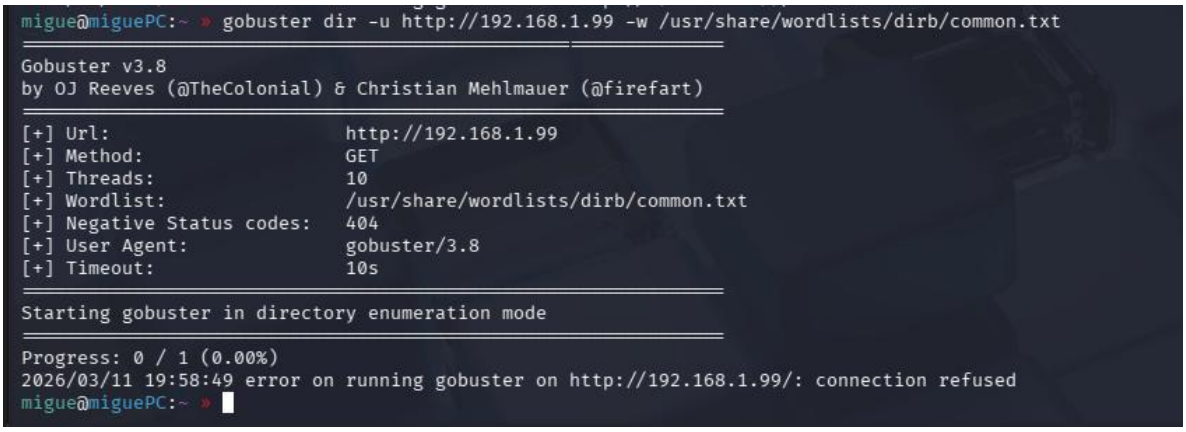
```
migue@miguePC:~ » nikto -h http://192.168.1.99
- Nikto v2.5.0
---------------------------------------------------------------------------
---------------------------------------------------------------------------
+ 0 host(s) tested
migue@miguePC:~ »
```

Descubrimiento de directorios

```
gobuster dir -u http://192.168.1.X -w
/usr/share/wordlists/dirb/common.txt
```

Identificar:

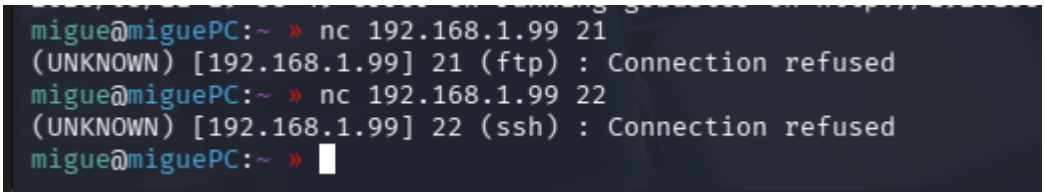
- directorios ocultos
- paneles de login
- archivos sensibles



3.4 Enumeración de banners

Con netcat

```
nc 192.168.1.X 21
nc 192.168.1.X 22
```

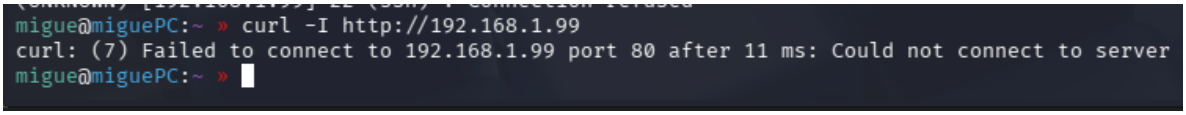


Con curl (web)

```
curl -I http://192.168.1.X
```

Analizar:

- versiones expuestas
- información sensible
- headers inseguros



Fase 3. Enumeración de usuarios (análisis cruzado)

El estudiante debe registrar usuarios encontrados desde:

- SMB
- RPC
- web
- banners

Llenar la siguiente Tabla

Fuente	Usuario encontrado
enum4linux	Usuarios locales vía SID: nobody, alumno1, migue. (Además de los grupos por defecto como administrator, root, etc.)
rpcclient	alumno1 (Obtenido exitosamente con una sesión nula)
web	Ninguno (Error: Connection refused)

Fase 4. Priorización de superficie de ataque

El estudiante debe clasificar:

Servicio	Riesgo	Motivo	Prioridad
SMB	Medio / Alto	El servicio Samba smbd 4 está expuesto y permite enumeración de sesiones nulas. Reveló recursos compartidos (IngenieriaShare, IPC$) y usuarios locales. Además, Nmap reporta "Message signing enabled but not required", lo que permite ataques de interceptación.	alta
SSH	Informativo Posiblemente bajo	El puerto se encuentra cerrado (Connection refused). No existe superficie de ataque explotable por esta vía.	baja

Servicio	Riesgo	Motivo	Prioridad
HTTP	bajo	El puerto web está cerrado (Connection refused a whatweb, nikto, gobuster y curl). No hay aplicativos web expuestos.	baja

Fase 5. Correlación de hallazgos

Responder:

1. ¿Qué servicio representa mayor riesgo?

   El servicio SMB (Samba) operando en los puertos 139 y 445. Es el único vector de entrada activo detectado en el escaneo completo

2. ¿Qué vector permitiría acceso inicial?

   Un ataque de fuerza bruta por diccionario sobre el servicio SMB dirigido a los usuarios confirmados (alumno1 o migue). Alternativamente, un ataque de *SMB Relay* aprovechando la debilidad en la firma de mensajes.

3. ¿Qué información facilita fuerza bruta?

   La obtención de los nombres de usuario exactos y la política de contraseñas filtrada por enum4linux, la cual reveló que la longitud mínima es muy débil (solo 5 caracteres) y la complejidad está deshabilitada ("Password Complexity: Disabled").

4. ¿Qué configuraciones son inseguras?

   La principal configuración insegura es permitir el acceso anónimo/sesiones nulas (evidenciado por el éxito de rpcclient), lo que permitió la fuga de información. Además, el no requerir la firma de mensajes SMB de forma obligatoria.

5. ¿Qué faltó por enumerar?

   Faltó ejecutar un escaneo de puertos UDP (nmap -sU) para verificar servicios como SNMP (161). También faltó intentar una autenticación directa usando los usuarios descubiertos (ej. smbclient //192.168.1.99/IngenieriaShare -U alumno1).

Fase 6. Reporte de enumeración

El estudiante debe entregar:

Hallazgos técnicos

- puertos abiertos
- usuarios encontrados
- shares accesibles
- tecnologías web

6. **Evidencias de práctica**
   Capuras de pantalla

- escaneo nmap completo
- salida enum4linux
- salida smbclient
- salida rpcclient
- resultados gobuster
- análisis de banners
- tabla de usuarios
- matriz de riesgo
- conclusiones

Recomendaciones si encn¿ontraron deficiencias de configuración en sus sistemas

- hardening SMB
- ocultar banners
- restringir enumeración anónima
- parcheo de servicios